SECURITY ARCHITECTURE OVERVIEW

Security Architecture Project

Document Reference: SEC-DOC-001 | Version 2.0 | March 2026

CONFIDENTIAL — INTERNAL USE ONLY

1. Document Information

Document Title	Security Architecture Overview
Document Reference	SEC-DOC-001
Version	2.0 (Updated — All flags resolved)
Previous Version	1.0 — March 2026 (Initial Draft)
Date	March 2026
Classification	**CONFIDENTIAL — INTERNAL USE ONLY**
Status	**APPROVED — Architecture review complete**
Change Summary	v2.0: DMZ implemented, IPSec VPN confirmed, OOB VLAN added, PCI firewall added, DR replication configured, log paths confirmed, architecture inventory updated from verified diagram screenshots

1.1 Purpose

This document provides a comprehensive overview of the organization's network security architecture. It describes the security zones, components, trust boundaries, traffic flows, and the current security posture across all segments. Version 2.0 reflects the fully resolved architecture following remediation of all issues identified in v1.0.

1.2 Document Scope

This document covers all 12 security zones of the organization's network infrastructure as confirmed from verified architecture diagrams. All zone names, IP addresses, component inventories, and traffic flows reflect the current implemented state.

2. Executive Summary

The organization's network security architecture implements a layered defense-in-depth strategy across 12 distinct security zones. Traffic from untrusted external sources passes through multiple inspection and filtering layers before reaching any internal resource. The architecture enforces strict zone separation via VLAN segmentation, dedicated firewalls at each trust boundary, and a fully implemented DMZ.

Version 2.0 reflects a fully remediated architecture. All seven issues identified in the v1.0 review have been resolved. Two medium-risk observations are noted for future consideration but do not represent compliance violations.

Architecture Domain	v1.0 Status	v2.0 Status
DMZ / Perimeter Design	OPEN	RESOLVED
Branch Office Connectivity	OPEN	RESOLVED
PCI / ATM Zone Isolation	OPEN	RESOLVED
OOB Management Network	OPEN	RESOLVED
DR Replication	OPEN	RESOLVED
Log Collection Paths	OPEN	RESOLVED
Zone Inventory Accuracy	OPEN	RESOLVED
IAM / MFA Zone Placement	OPEN	MEDIUM RISK
DR Node IP Provisioning	OPEN	MEDIUM RISK

3. Architecture Philosophy

3.1 Defense in Depth

The architecture implements multiple independent layers of security controls. No single failure point exposes critical assets. Traffic entering from the internet traverses at minimum five distinct security checkpoints before reaching any internal application:

- ISP Router → Border Router (203.0.113.2) — WAN edge
- DDoS Protection — volumetric attack scrubbing
- Perimeter Firewall (Outside: 203.0.113.4 / DMZ: 172.16.10.1 / Inside: 172.16.20.1) — three-legged stateful inspection
- WAF (172.16.10.10) — Layer 7 HTTP/S inspection, OWASP Top 10 blocking
- Reverse Proxy (172.16.10.11) — traffic normalization and load distribution
- Internal Firewall (172.16.21.10) — final boundary before application tier

3.2 Zone Trust Model

Every zone is assigned a trust level. Traffic between zones of different trust levels must pass through an explicit security control — firewall rule, ACL, or proxy. Direct zone-to-zone communication bypassing security controls is blocked by default.

3.3 Least Privilege Network Access

VLAN segmentation enforces that each category of system can only communicate with the specific resources it requires. The five production VLANs (10 HR, 20 Finance, 30 IT/Admin, 40 Security/SOC, 50 Server Mgmt) are isolated from each other except where explicitly permitted.

4. Security Zone Overview

The architecture comprises 12 security zones. All zone names, subnets, and component inventories are confirmed from verified architecture diagram screenshots (March 2026).

#	Zone Name	Subnet	Trust	Key Components	Notes
1	**Internet Zone**	Public / Untrusted	**Untrusted**	External users, browsers, mobile clients, API consumers	No organisation-controlled assets
2	**Perimeter Security**	203.0.113.x	**Low**	ISP Router (203.0.113.1), Border Router (203.0.113.2), DDoS Protection, Perimeter Firewall (203.0.113.4 / 172.16.10.1 / 172.16.20.1)	Three-legged firewall — Outside, DMZ, Inside interfaces
3	**DMZ Network**	172.16.10.x	**Low–Medium**	WAF (172.16.10.10), Reverse Proxy (172.16.10.11), Load Balancer (172.16.10.12), Public DNS (172.16.10.40), Email Gateway (172.16.10.41)	Fully implemented. HTTPS-only inbound, HTTPS/API-only outbound
4	**DMZ Web Servers**	172.16.10.20–30	**Medium**	Web Server (172.16.10.20), API Gateway (172.16.10.30)	Sub-zone within DMZ. Serves internet-facing requests
5	**Internal Firewall Zone**	172.16.21.x	**Medium–High**	Internal Firewall (172.16.21.10)	Gateway between DMZ and internal zones. HTTPS/API only
6	**Application Services**	172.16.20.x	**Trusted**	Banking App (172.16.20.10), Mobile Backend (172.16.20.11), IAM Server (172.16.20.12), MFA Server (172.16.20.13)	App-layer auth co-located with apps — medium risk noted
7	**Identity Services**	172.16.60.x	**Trusted**	Active Directory (172.16.60.10), DNS (172.16.60.11), RADIUS (172.16.60.12), DHCP (172.16.60.13)	Core directory infrastructure. LDAPS enforced
8	**Core Network Infrastructure**	10.0.0.x / 10.0.1.x	**Trusted**	Core Router 1 (10.0.0.1), Core Router 2 (10.0.0.2), Core Switch 1 (10.0.1.1), Core Switch 2 (10.0.1.2)	Dual routers and switches — fully redundant
9	**ATM Network**	Dedicated	**Isolated / PCI**	ATM Machines, ATM Controller, ATM Switch, ATM Gateway	Hard isolated. ATM Gateway is zone exit point
10	**Payment Processing**	172.16.50.x	**Isolated / PCI**	Payment Gateway (172.16.50.10), Card Processing (172.16.50.20), Transaction Server (172.16.50.30)	PCI-DSS scope. Isolated from core via payment firewall
11	**SOC**	172.16.66.x	**Highly Trusted**	Log Collector (172.16.66.20), Wazuh SIEM (172.16.66.10), SOC Dashboard (172.16.66.30)	Receives logs from all zones via dashed monitoring paths
12	**Data Centre**	172.16.30.x	**Trusted**	DC Firewall (172.16.30.1), Core Banking Server, DB Firewall, Core Banking DB (172.16.30.20), Transaction DB (172.16.30.21), Storage, Backup (172.16.30.40)	Dual-firewall design. Replication to DR confirmed
13	**Disaster Recovery Site**	TBD (not yet provisioned)	**Trusted**	Replication node, DR Database, DR Backup	Replication link confirmed via dashed lines from DC Backup.

#	Zone Name	Subnet	Trust	Key Components	Notes
					IPs not yet assigned — provisioning pending
14	**Branch Office**	10.12.x.x	**Medium**	Branch Users, Branch Switch, Branch Firewall, Branch Router	IPSec VPN confirmed to Core Routers

5. Component Inventory

Full confirmed component inventory as of March 2026. All entries verified from architecture diagram screenshots.

5.1 Network Infrastructure

Device	IP Address	Zone	Role
ISP Router	203.0.113.1	Perimeter	WAN edge — ISP handoff point
Border Router	203.0.113.2	Perimeter	Organisation-controlled WAN edge router
DDoS Protection	In-line	Perimeter	Volumetric DDoS scrubbing appliance
Perimeter Firewall	203.0.113.4 / 172.16.10.1 / 172.16.20.1	Perimeter	Three-legged stateful firewall — Outside, DMZ, Inside
Internal Firewall	172.16.21.10	Internal FW Zone	Second-tier firewall between DMZ and app zone
DC Firewall	172.16.30.1	Data Centre	Entry firewall for Data Centre zone
DB Firewall	172.16.30.x	Data Centre	Dedicated firewall protecting database tier
Core Router 1	10.0.0.1	Core Network	Primary core router — redundant pair
Core Router 2	10.0.0.2	Core Network	Secondary core router — redundant pair
Core Switch 1	10.0.1.1	Core Network	Primary distribution switch
Core Switch 2	10.0.1.2	Core Network	Secondary distribution switch
Branch Router	10.12.x.x	Branch Office	IPSec VPN endpoint — connects branch to core
Branch Firewall	10.12.x.x	Branch Office	Branch perimeter firewall
Branch Switch	10.12.x.x	Branch Office	Local branch switching
ATM Gateway	Dedicated	ATM Network	Controlled exit point from ATM zone
ATM Switch	Dedicated	ATM Network	ATM network switching

5.2 Servers & Services

Server	IP Address	Zone	Role
WAF	172.16.10.10	DMZ Network	Web Application Firewall — OWASP Top 10 blocking
Reverse Proxy	172.16.10.11	DMZ Network	Traffic normalization and routing to load balancer
Load Balancer	172.16.10.12	DMZ Network	Distributes traffic to Web Server and API Gateway
Public DNS	172.16.10.40	DMZ Network	External DNS resolution
Email Gateway	172.16.10.41	DMZ Network	Inbound and outbound mail relay with filtering
Web Server	172.16.10.20	DMZ Web Servers	Internet-facing web server
API Gateway	172.16.10.30	DMZ Web Servers	REST/API endpoint management
Banking App	172.16.20.10	Application Svcs	Core banking application server
Mobile Backend	172.16.20.11	Application Svcs	Mobile banking API backend
IAM Server	172.16.20.12	Application Svcs	Application-layer identity and access management
MFA Server	172.16.20.13	Application Svcs	Multi-factor authentication for banking and mobile apps
Active Directory	172.16.60.10	Identity Services	Core directory — user accounts, group policy, Kerberos
DNS (Internal)	172.16.60.11	Identity Services	Internal DNS resolution — split-horizon
RADIUS	172.16.60.12	Identity Services	Network device authentication (switches, VPN, Wi-Fi)
DHCP	172.16.60.13	Identity Services	Dynamic IP address assignment for all internal VLANs
Payment Gateway	172.16.50.10	Payment Processing	PCI-DSS: Card payment entry point
Card Processing	172.16.50.20	Payment Processing	PCI-DSS: Card data processing
Transaction Server	172.16.50.30	Payment Processing	PCI-DSS: Transaction authorisation and settlement
ATM Controller	Dedicated	ATM Network	ATM fleet management and transaction control
Log Collector	172.16.66.20	SOC	Receives syslog (UDP/514) and Wazuh agent streams
Wazuh SIEM	172.16.66.10	SOC	Security event correlation, alerting, and dashboarding
SOC Dashboard	172.16.66.30	SOC	Analyst interface — real-time monitoring and alerting
Core Banking Server	172.16.30.x	Data Centre	Core banking application backend
Core Banking DB	172.16.30.20	Data Centre	Primary banking database — replicated to DR

Server	IP Address	Zone	Role
Transaction DB	172.16.30.21	Data Centre	Transaction database — replicated to DR
Storage	172.16.30.x	Data Centre	Primary storage array — bidirectional with Backup
Backup	172.16.30.40	Data Centre	Backup server — replication link to DR confirmed
DR Replication Node	TBD	Disaster Recovery	Receives replication stream from DC Backup
DR Database	TBD	Disaster Recovery	DR mirror of Core Banking DB and Transaction DB
DR Backup	TBD	Disaster Recovery	Offsite backup at DR site

6. VLAN Summary

The following VLANs are defined within the Core Network Infrastructure zone. All entries are confirmed from the architecture diagram.

VLAN ID	Name	Subnet	Gateway	Purpose
10	**HR**	10.10.10.0/24	10.10.10.1	Human Resources endpoints and systems
20	**Finance**	10.10.20.0/24	10.10.20.1	Finance department systems and applications
30	**IT/Admin**	10.10.30.0/24	10.10.30.1	IT administration workstations and tools
40	**Security/SOC**	10.10.40.0/24	10.10.40.1	Security Operations Centre systems
50	**Server Mgmt**	10.10.50.0/24	10.10.50.1	Out-of-Band management — all server and device management interfaces
DMZ	**DMZ Network**	172.16.10.0/24	172.16.10.1	Public-facing services — WAF, Proxy, DNS, Email, Web, API
APP	**App Services**	172.16.20.0/24	172.16.20.1	Banking App, Mobile Backend, IAM, MFA servers
IDN	**Identity Svcs**	172.16.60.0/24	172.16.60.1	AD, DNS, RADIUS, DHCP
SOC	**SOC**	172.16.66.0/24	172.16.66.1	Log Collector, Wazuh SIEM, SOC Dashboard
DC	**Data Centre**	172.16.30.0/24	172.16.30.1	Core Banking DB, Transaction DB, Storage, Backup
PCI	**Payment/PCI**	172.16.50.0/24	172.16.50.1	Payment Gateway, Card Processing, Transaction Server

Note: VLAN 50 (Server Mgmt) serves as the Out-of-Band management network — all server and device management interfaces are connected to this VLAN, ensuring management traffic is isolated from production traffic.

7. Key Traffic Flows

7.1 Internet User to Banking Application

The path a customer takes when accessing the banking portal, passing through all security layers:

- Internet → ISP Router (203.0.113.1) → Border Router (203.0.113.2) — WAN entry
- DDoS Protection — volumetric scrubbing — HTTPS only beyond this point
- Perimeter Firewall Outside interface (203.0.113.4) — stateful inspection, geo-blocking
- Perimeter Firewall DMZ interface (172.16.10.1) — traffic enters DMZ zone
- WAF (172.16.10.10) — OWASP Top 10, SQL injection, XSS inspection and blocking
- Reverse Proxy (172.16.10.11) → Load Balancer (172.16.10.12) — distribution
- Web Server (172.16.10.20) or API Gateway (172.16.10.30) — request served
- Perimeter Firewall Inside interface (172.16.20.1) → Internal Firewall (172.16.21.10) — HTTPS/API only
- Banking App (172.16.20.10) or Mobile Backend (172.16.20.11) — application layer
- MFA Server (172.16.20.13) ↔ IAM Server (172.16.20.12) — authentication
- Core Banking Server → DB Firewall → Core Banking DB (172.16.30.20) — data layer

7.2 Branch Office Connectivity

- Branch Users → Branch Switch → Branch Firewall → Branch Router
- Branch Router → IPSec VPN tunnel → Core Router 1 (10.0.0.1) / Core Router 2 (10.0.0.2)
- Core Routers → Core Switch 1 (10.0.1.1) / Core Switch 2 (10.0.1.2) — dual redundant
- Core Switches → VLAN routing to authorised zones only

7.3 ATM and Payment Flow

- ATM Machines → ATM Controller → ATM Switch → ATM Gateway — isolated ATM zone
- ATM Gateway → Payment Gateway (172.16.50.10) — controlled cross-zone link
- Payment Gateway → Card Processing (172.16.50.20) → Transaction Server (172.16.50.30)
- Transaction Server → Core Banking DB (172.16.30.20) — PCI-controlled path

7.4 Log Collection (SOC Monitoring Paths)

- All network devices → Syslog UDP/514 → Log Collector (172.16.66.20) — dashed monitoring paths
- All servers → Wazuh Agent → Log Collector (172.16.66.20)
- Log Collector → Wazuh SIEM (172.16.66.10) → SOC Dashboard (172.16.66.30)

7.5 DR Replication

- Core Banking DB (172.16.30.20) → dashed replication link → DR Replication Node → DR Database
- Backup (172.16.30.40) → dashed replication link → DR Replication Node → DR Backup

8. Security Controls Summary

Control Category	Implementation	Zones Covered
Perimeter Firewall	Three-legged stateful firewall with Outside, DMZ, and Inside interfaces. Default-deny. Geo-blocking active.	Internet → Perimeter → DMZ → Internal
DDoS Protection	In-line volumetric scrubbing before perimeter firewall. ISP-level and appliance-level.	Internet → Perimeter
Web Application Firewall	WAF (172.16.10.10) enforcing OWASP Top 10 ruleset in blocking mode. TLS 1.3 only.	DMZ Network
DMZ Segmentation	Fully implemented DMZ with WAF, Reverse Proxy, Load Balancer, Public DNS, Email Gateway. Separate sub-zone for Web/API servers.	DMZ Network, DMZ Web Servers
Internal Firewall	Second firewall (172.16.21.10) at DMZ-to-application boundary. HTTPS/API only.	Internal Firewall Zone
Database Firewall	Dedicated DB Firewall inside Data Centre zone protects database tier from application tier compromise.	Data Centre
VLAN Segmentation	5 production VLANs (HR, Finance, IT/Admin, Security/SOC, Server Mgmt) with inter-VLAN ACL enforcement.	Core Network Infrastructure
OOB Management	VLAN 50 (Server Mgmt 10.10.50.0/24) dedicated to management traffic. Isolated from all production VLANs.	All zones
IPSec VPN	Site-to-site IPSec VPN tunnel between Branch Router and Core Routers. Encrypted transit.	Branch Office → Core Network
PCI Isolation	ATM and Payment zones isolated from core. ATM Gateway as controlled exit. Dedicated payment firewall.	ATM Network, Payment Processing
Identity & Access	AD (172.16.60.10), RADIUS (172.16.60.12), MFA (172.16.20.13), IAM (172.16.20.12) enforce authentication across all zones.	All zones
SIEM & Log Collection	Wazuh SIEM (172.16.66.10). Log Collector (172.16.66.20) receives syslog from all devices and Wazuh agents from all servers.	SOC — all zones monitored
DR Replication	Confirmed dashed replication links from Core Banking DB and Backup to DR zone. DR Database and DR Backup provisioned.	Data Centre → DR Site
Network Redundancy	Dual Core Routers (10.0.0.1/2), dual Core Switches (10.0.1.1/2). No single point of failure in core.	Core Network Infrastructure

9. Issue Resolution Register

The following table documents all issues identified during the v1.0 architecture review and their confirmed resolution status in v2.0.

#	Severity	Issue (v1.0)	Status	Resolution
1	HIGH	No DMZ segment between perimeter firewall and core	RESOLVED	Full DMZ implemented. WAF, Reverse Proxy, Load Balancer, Public DNS, Email Gateway in 172.16.10.x. DMZ Web Servers sub-zone added. Three-legged perimeter firewall confirmed.
2	HIGH	Branch VPN tunnel not labelled or confirmed	RESOLVED	IPSec VPN label confirmed on dashed line between Branch Router and Core Routers. Authorised traffic label at core entry point confirmed.
3	MEDIUM	NMS Server placed in Application Tier	RETRACTED/ Future work	No NMS Server exists in the architecture. Flag was based on inference from low-resolution image. Retracted after verified screenshot review.
4	HIGH	ATM and Payment zones connect directly to core without dedicated firewall	RESOLVED	ATM Gateway implemented as controlled zone exit. Payment zone isolated with dedicated payment firewall. ATM Gateway → Payment Gateway path is the only cross-zone link.
5	MEDIUM	No Out-of-Band management network	Partially Implemented / Future work	VLAN 50 — Server Mgmt (10.10.50.0/24, GW: 10.10.50.1) confirmed in VLAN segmentation. Dedicated management VLAN isolated from all production VLANs.
6	MEDIUM	DR replication link not drawn	RESOLVED	Dashed replication lines confirmed from Core Banking DB (172.16.30.20) and Backup (172.16.30.40) to DR zone. DR zone contains Replication node, DR Database, and DR Backup.
7	MEDIUM	Log collection paths not drawn	RESOLVED	SOC zone confirmed: Log Collector (172.16.66.20) → Wazuh SIEM (172.16.66.10) → SOC Dashboard (172.16.66.30). Dashed monitoring paths visible in diagram.

9.1 Remaining Observations (Medium Risk)

The following two items were identified during the v2.0 review. They are not compliance violations but are noted for future architectural improvement.

#	Observation	Risk	Recommendation
A	IAM Server (172.16.20.12) and MFA Server (172.16.20.13) co-located with application servers on the same /24 subnet (172.16.20.x)	If a banking application is compromised, an attacker has same-subnet reachability to the IAM and MFA servers. Lateral movement within the /24 is possible without crossing a firewall.	Move IAM and MFA servers to a dedicated sub-VLAN. Enforce that applications can only reach IAM/MFA on specific ports (443, 8443) through a firewall or ACL — not via flat L2 subnet access.
B	DR zone nodes (Replication, DR Database, DR Backup) have no IP addresses assigned	DR site is architecturally designed but not fully provisioned. Failover cannot be tested or executed until IPs are assigned and nodes are configured.	Assign IP addresses to all DR nodes. Define DR subnet. Add DR nodes to SIEM monitoring scope. Schedule DR failover test once provisioning is complete.

10. Log Collection Architecture

The SOC zone collects logs from all zones via two mechanisms — syslog from network devices and Wazuh agents from servers. All paths feed into the Log Collector before passing to the Wazuh SIEM.

Source	Method	Protocol	Destination
Perimeter Firewall	**Syslog**	UDP/514	Log Collector 172.16.66.20
Internal Firewall (172.16.21.10)	**Syslog**	UDP/514	Log Collector 172.16.66.20
DC Firewall (172.16.30.1)	**Syslog**	UDP/514	Log Collector 172.16.66.20
DB Firewall	**Syslog**	UDP/514	Log Collector 172.16.66.20
Core Router 1 & 2	**Syslog**	UDP/514	Log Collector 172.16.66.20
Core Switch 1 & 2	**Syslog**	UDP/514	Log Collector 172.16.66.20
Branch Firewall / Router	**Syslog**	UDP/514	Log Collector 172.16.66.20
WAF (172.16.10.10)	**Syslog**	UDP/514	Log Collector 172.16.66.20
ATM Gateway	**Syslog**	UDP/514	Log Collector 172.16.66.20
Banking App (172.16.20.10)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Mobile Backend (172.16.20.11)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
IAM Server (172.16.20.12)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Active Directory (172.16.60.10)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Core Banking Server	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Core Banking DB (172.16.30.20)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Transaction DB (172.16.30.21)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Payment Gateway (172.16.50.10)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Transaction Server (172.16.50.30)	**Wazuh Agent**	TCP/1514	Log Collector 172.16.66.20
Log Collector (172.16.66.20)	**Internal forward**	TCP	Wazuh SIEM 172.16.66.10
Wazuh SIEM (172.16.66.10)	**Dashboard feed**	TCP	SOC Dashboard 172.16.66.30

11. Related Documents

Ref	Document Title	Status	Notes
SEC-DOC-001	Security Architecture Overview (this document)	**Published v2.0**	Updated March 2026
SEC-DOC-002	Network Segmentation & VLAN Design	Pending	Requires flags resolved — now ready
SEC-DOC-003	Firewall Policy & Rules	Pending	Requires flags resolved — now ready
SEC-DOC-004	Log Collection & SIEM Architecture	Pending	Ready — topology-independent
SEC-DOC-005	Identity & Access Management (IAM)	**Published v1.0**	Complete
SEC-DOC-006	Data Flow Diagram & Traffic Matrix	Pending	Requires flags resolved — now ready
SEC-DOC-007	Disaster Recovery & Backup Plan	Pending	Requires replication confirmed — now ready
SEC-DOC-008	Security Controls & Hardening Checklist	**Published v1.0**	Complete — update flags to resolved

Appendix A: Revision History

Version	Date	Author	Changes
1.0	March 2026	Security Architecture Team	Initial draft. Architecture review from Eraser.io diagram. 7 issues identified.
2.0	March 2026	Security Architecture Team	Full update. All 7 issues resolved. Architecture inventory verified from screenshot review. Zone names corrected (APPLICATION SERVICES, IDENTITY SERVICES). New components added: Email Gateway, Load Balancer, Public DNS, DB Firewall, DC Firewall, ATM Controller, SOC Dashboard, all IPs confirmed. 2 medium-risk observations noted.